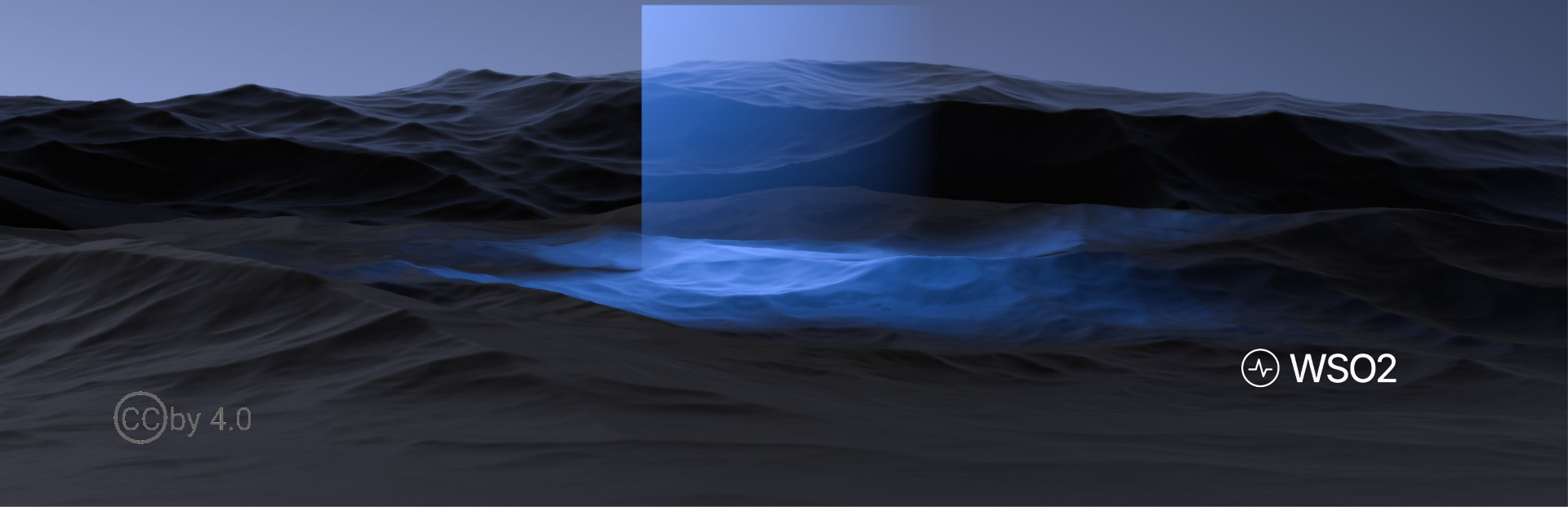
Users and Roles



CC by 4.0

WSO2

Who Uses API Manager?

WSO2

Types of Users

API Creator

Publisher
Designs and builds APIs: resources, endpoints, policies and documentation.

API Publisher

Publisher
Owns the API lifecycle: publishes, deprecates and retires APIs, manages subscriptions.

API Consumer

Developer Portal
Application developer: finds APIs, subscribes, generates keys and calls the APIs.

Administrator

Admin Portal and Management Console
Users and roles, rate limiting policies, workflows, gateways and key managers.

DevOps

apictl / CI-CD
Imports and exports APIs, API Products and applications between environments.

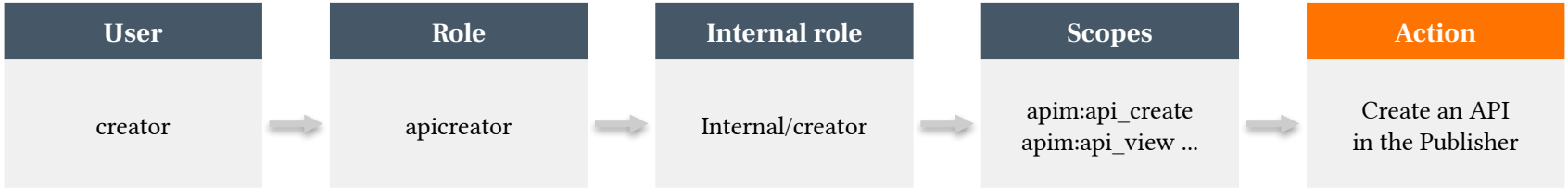
Observer / Analytics

Publisher (read only) / Analytics
Views APIs and settings without changing them, or views usage dashboards.

Where Each User Works

Publisher	Developer Portal	Admin Portal	Management Console	API Controller
`/publisher`	`/devportal`	`/admin`	`/carbon`	`apictl`
API Creator	API Consumer	Administrator	Administrator: users, roles, user stores	DevOps
API Publisher	Anonymous visitors (browse only)			CI-CD pipelines
Observer				

Users, Roles and Permissions



A user gets access only through roles
Permissions are never given to a user directly.

A role groups permissions
Give access once to the role and every user in it gets it.

In 4.7.0 the portals check OAuth2 scopes
Each scope is bound to roles, so the role decides what the token allows.

Built-in Roles in API Manager 4.7.0

Role	Typical user	What it allows
admin	Administrator	Everything, including the Admin Portal and the Management Console
Internal/creator	API Creator	Create, edit, delete and deploy APIs; documents, policies, certificates
Internal/publisher	API Publisher	Change the API lifecycle (publish, deprecate, retire); manage and block subscriptions
Internal/subscriber	API Consumer	Log in to the Developer Portal; create applications, subscribe, generate keys
Internal/devops	DevOps	Import and export APIs, API Products, applications and policies (apictl)
Internal/observer	Auditor / reviewer	Read-only view of APIs and policies in the Publisher
Internal/analytics	Business / operations	View analytics and monitoring dashboards
Internal/integration_dev	Integration developer	List APIs and read API definitions from developer tools
Internal/everyone	Every user	Given to all users automatically; grants no portal access on its own

Creator vs Publisher: Separation of Duties

API Creator

Can

- Create and edit APIs
- Define resources, endpoints and policies
- Write API documentation
- Create revisions and deploy them to a gateway

Cannot publish an API or change its lifecycle

API Publisher

Can

- Publish, deprecate, block and retire APIs
- Create API Products
- Manage and block subscriptions
- View all APIs

Cannot create a new API

Why: a change to a live API needs two people, one to build it and one to approve it going public.

How Access Is Checked in 4.7.0

1. User logs in to a portal
2. Portal asks the Key Manager for a token with scopes
3. Key Manager checks the user's roles against the scope-role mapping
4. Token carries only the scopes the roles allow
5. Portal REST API call is allowed or refused

Scope	Needed for	Default role
apim:api_create	Creating an API	Internal/creator
apim:api_publish	Publishing an API	Internal/publisher
apim:subscribe	Subscribing to an API	Internal/subscriber
apim:admin	Admin Portal	admin

Where the mapping lives

tenant-conf.json, shown in the Admin Portal under Settings > Advanced and Settings > Scope Assignments.

Custom Roles Need a Role Mapping

1. Create the role	2. Map the role	3. Assign users
Management Console Users and Roles > Add New Role e.g. apicreator	Admin Portal Settings > Scope Assignments Add scope mappings	Management Console Add the users to the role e.g. creator

Option A: Role alias	Option B: Custom scopes
Map the custom role to a built-in role, e.g. apicreator → Internal/creator. It gets every scope of that role. Used in Lab 02.	Select individual scopes for the role. Use this when no built-in role matches, e.g. view-only access to some features.

The role must exist before it can be mapped.
A custom role with no mapping gives no access to the Publisher or Developer Portal.

Where Users Come From

Primary user store	Built-in database by default. Users created in the Management Console are stored here.
Secondary user stores	LDAP or Active Directory, added later. Covered in Day 2, Lab 11.
Self sign-up	A user registers in the Developer Portal and gets Internal/subscriber automatically.
Super admin	The first admin user, defined under [super_admin] in deployment.toml.

Groups from LDAP or Active Directory can be linked to API Manager roles. Covered in Day 2, Lab 12.